



Product · Engineering · Security

Product Requirements Document

Product Requirements Document

EDR Compliance Dashboard

A complete picture of who the product is for, what it must do, and how we'll know it's working.

PRD v1.0

Multi-vendor EDR

Self-hosted

RBAC

MFA

Audit-ready

GDPR-friendly

Version: 1.0

Last updated: June 25, 2026

Audience: Product, Engineering, Security, Compliance

Contents

1	1. Document control
2	2. Executive summary
3	3. Problem statement
4	4. Goals and non-goals
5	5. Target users and personas
6	6. User stories
7	7. Functional requirements
8	8. Non-functional requirements
9	9. Acceptance criteria summary
10	10. Success metrics
11	11. Out of scope for v1.0
12	12. Roadmap (post-v1.0 candidates)
13	13. Risks and open questions
14	14. Glossary
15	Appendix A — Default seeded users
16	Appendix B — Reference deployment

1. Document control

FIELD	VALUE
Document	Product Requirements Document (PRD)
Product	EDR Compliance Dashboard
Version	1.0 (initial release)
Status	Released
Owner	Faisal Khan
Stakeholders	Security operations, Compliance, Engineering, Executive
Related	Technical Reference (DOCUMENTATION . pdf), API reference
Revision policy	This document is updated whenever scope or requirements change. Minor changes bump the patch version; new feature areas bump the minor version

2. Executive summary

Organizations running endpoint detection and response (EDR) tools — CrowdStrike, Microsoft Defender, SentinelOne, Wazuh, Trend Micro, Cortex, Cisco AMP, Elastic, Sophos and others — get a separate dashboard for each tool. When the estate spans more than one product (which it almost always does), or when non-operational stakeholders (compliance auditors, executives) need a view, teams resort to spreadsheets, screenshots, and ad-hoc exports.

The **EDR Compliance Dashboard** is a self-hosted platform that:

- **Unifies** endpoint inventory across multiple vendors via a pluggable

connector framework, normalizes the records into one canonical shape, and persists periodic snapshots so trends survive vendor outages.

- **Visualizes** the estate through user-customizable dashboards (pie /

donut / bar / line / area / stat / gauge / table widgets) with rich per-widget configuration and click-to-drill behavior.

- **Delegates** safely: admins assign read-only dashboards to viewers

(compliance, exec sponsors) without granting them access to the underlying EDR consoles. Updates the admin makes propagate live to viewers.

- **Notifies** the right people when something changes — new sign-in

locations, failed source pulls, newly disclosed CVEs in installed dependencies, dashboard assignments — through a fully editable email template system.

- **Audits** every administrative and security-relevant action.

- **Watches its own back** with a built-in CVE scanner for the system's own

PHP + npm dependencies.

This PRD captures every feature in the v1.0 release with formal requirements, user stories, and acceptance criteria.

3. Problem statement

3.1 What we observed

- A typical mid-market security team runs **two to five** endpoint security products. Each has its own console, its own definition of "online" / "compliant" / "non-compliant", and its own export format.
- Compliance audits demand an estate-wide view (e.g. "what percentage of endpoints are running an agent version newer than X?"). Producing this requires manual reconciliation across the vendor consoles, taking hours per audit cycle.
- Sharing visibility with non-operational stakeholders (auditors, board reporters) by giving them direct EDR console access carries security and licensing risks. Most teams resort to PDF screenshots, which are obsolete the moment they're produced.
- When source ingest fails (vendor API outage, expired token), the SOC often doesn't notice until someone asks about a dashboard that has silently stopped updating.
- New CVEs in the dashboard's own software stack go unnoticed until a scheduled vulnerability scan flags them weeks later.

3.2 What goes wrong because of this

- Compliance % is reported as a point-in-time snapshot, not a trend, so drift goes unnoticed for days or weeks.
- High-value endpoints (e.g. domain controllers) that go non-compliant get buried in a per-product report instead of bubbling to the top of a unified view.
- Read-only viewers either don't see anything, or get over-privileged access to the EDR console "because it was easier".
- SOC operators spend more time on report production than on investigation.

3.3 What we set out to solve

A single, vendor-agnostic, self-hosted platform that gives security and compliance teams one place to see the estate, drill into outliers, share sanitized views, and stay informed when things change — without becoming another EDR product or another SIEM.

4. Goals and non-goals

4.1 Goals (in scope for v1.0)

#	GOAL
G1	Multi-vendor endpoint inventory unification with a pluggable connector framework
G2	Persistent snapshot history enabling trend analysis (not just live polling)
G3	Custom dashboard builder with drag/resize layout and 8 widget types
G4	Per-widget customization (sort, top-N, palette, thresholds, granularity, etc.)
G5	Click-to-drill from any chart slice to the underlying endpoint table
G6	Admin-controlled read-only dashboard sharing with live updates
G7	Role-based access control with three roles (admin / analyst / viewer)
G8	TOTP-based multi-factor authentication, admin-controlled enrollment
G9	Email notification system with editable templates and per-user subscriptions
G10	Continuous CVE scanning of the dashboard's own dependency stack
G11	Comprehensive audit trail for security and compliance review
G12	Self-hostable on a standard Linux VPS with no managed services required

4.2 Non-goals (explicitly out of scope for v1.0)

#	NON-GOAL	WHY
N1	Replace an EDR / XDR	Depends on vendor APIs as data sources; not an agent or detector
N2	Replace a SIEM	Ingests endpoint inventory, not raw security events
N3	Real-time push notifications	Vendor APIs are polled on a schedule; near-real-time only
N4	Mobile native apps	Responsive web is sufficient for the target user workflows
N5	Multi-tenant SaaS	Designed for single-tenant self-hosted deployment
N6	Ticketing / case management	Surfaces issues; remediation happens in other tools
N7	AI / ML anomaly detection	Threshold + rule-based detection is sufficient for v1.0
N8	Endpoint remediation actions (isolate, kill process)	Read-only against vendor APIs by design

4.3 Guiding principles

1. **Vendor agnostic.** No single connector class is privileged. Adding a new vendor is a localized change.

1. **Self-hostable with stock infrastructure.** PHP + MySQL + Node. No required external services beyond an SMTP provider.

1. **Read-only by default for non-managers.** Viewers see what admins share. No accidental writes.

1. **Audit everything that matters.** Every admin action, every login, every dashboard view by a viewer.

1. **Don't surprise the user.** New IPs flagged, source failures notified, new CVEs notified — silently failing is unacceptable.

1. **Configuration as data, not env vars.** SMTP, mail templates, subscriptions, source credentials all live in the database and are editable via the UI. The `.env` should be set once at deploy time.

5. Target users and personas

The system is designed around three concrete personas. Every feature is attributed to the personas it serves.

5.1 Persona P1 — Security Administrator (`role = admin`)

"I own this deployment. I configure the sources, manage who has access, set up notifications, and answer the auditor's questions."

ATTRIBUTE	VALUE
Title	Information Security Manager / Sec Ops Lead
Experience	5+ years in security operations
Frequency of use	Daily
Technical depth	High — familiar with EDR consoles, OAuth, REST APIs
Primary device	Laptop, dual-monitor desk setup
Critical needs	Configurability, audit visibility, complete control, MFA enforcement
Pain points if missing	Compliance audit failures, can't delegate visibility safely

5.2 Persona P2 — SOC Analyst (`role = analyst`)

"I watch the estate every day. I need to spot the unhealthy boxes fast, dig into why, and build the dashboard that fits my workflow."

ATTRIBUTE	VALUE
Title	Security Operations Center Analyst
Experience	1–5 years
Frequency of use	Several times per shift
Technical depth	Medium — knows the EDR products in depth, less familiar with infrastructure
Primary device	Workstation with multiple monitors
Critical needs	Speed, drill-down, filtering, ability to save custom widgets
Pain points if missing	Manual reconciliation across vendor consoles

5.3 Persona P3 — Compliance Auditor / Executive (`role = viewer`)

"I need to see compliance % and unhealthy endpoint counts for my quarterly review. I don't want — and shouldn't have — access to the underlying EDR tools."

ATTRIBUTE	VALUE
Title	Compliance Officer / Risk Manager / CISO / Board reporter
Experience	Varies; security-aware but not operator-level
Frequency of use	Weekly to quarterly
Technical depth	Low to medium — wants charts, not raw data
Primary device	Laptop
Critical needs	Clear visualization, no clutter, no risk of breaking anything, trustworthy data
Pain points if missing	Has to ask SOC for reports; reports go stale immediately

5.4 Persona coverage matrix

Each feature must demonstrably serve at least one persona.

FEATURE AREA	P1 ADMIN	P2 ANALYST	P3 VIEWER
Sign in (password + MFA)	•	•	•
Source management	•	•	—
Dashboard builder	•	•	—
Drill-down on charts	•	•	•
Endpoint data table	•	•	—
Dashboard switcher (viewer multi-assign)	—	—	•
Dashboard assignment to viewers	•	—	—
User management	•	—	—
Mail / template config	•	—	—
Notification subscriptions (mine)	•	•	•
Tech stack / CVE scan	•	—	—
Audit log	•	—	—
Roles & Permissions explainer	•	•	•

6. User stories

User stories are grouped by persona. Each story is referenced by a stable ID (U-001 , U-

002 , ...) so requirements in section 7 can cite them.

6.1 P1 — Security Administrator stories

ID	AS AN ADMIN, I WANT TO...	...SO THAT...
U-001	Sign in with my email and password, then a TOTP code from my authenticator	Account access is protected by two factors
U-002	Be alerted the moment any user signs in from an IP that's not in their baseline	I can investigate a possible account compromise immediately
U-003	Have accounts auto-lock after N failed sign-in attempts	Brute-force attacks are throttled without my intervention
U-004	Create users with specific roles and force them to change their password on first login	New team members are onboarded safely
U-005	Reset another user's password and have them notified by email	I can unblock someone who's forgotten their credentials
U-006	Require a user to enroll MFA on their next login	I can enforce a security policy without scheduling a meeting with them
U-007	Reset a user's MFA when they lose their authenticator device	They can recover without me knowing their secret
U-008	Delete a user account, with a typed-confirmation safeguard against accidents	Departing employees lose access cleanly
U-009	Connect to my organization's EDR API by choosing the vendor preset, entering credentials, and testing the connection	I don't have to read the vendor's API docs to get started
U-010	Build a dashboard with any combination of stat, gauge, pie, bar, line, area, and table widgets	I can shape the view to my organization's reporting needs
U-011	Assign one or more of my dashboards to a viewer	A compliance auditor sees exactly the curated view I prepared
U-012	See an audit log of who viewed which dashboards and when	I can answer "who saw the Q3 compliance report?"
U-013	Configure SMTP credentials through the admin UI without touching <code>.env</code>	I don't need a deploy to change mail settings
U-014	Edit the subject and body of every notification template, with live preview and a test send	Notifications match my organization's tone and detail level
U-015	See a live inventory of every PHP and npm package installed, with any matching CVEs from Packagist and the GitHub Advisory Database	I know my dashboard's own dependencies are safe

ID	AS AN ADMIN, I WANT TO...	...SO THAT...
U-016	Be notified the moment a new CVE is disclosed affecting an installed package	I patch before the vulnerability is exploited
U-017	See the System Health page: subsystem status (DB, cache, queue, scheduler, sources, security posture)	I can diagnose problems without SSHing in

6.2 P2 — SOC Analyst stories

ID	AS AN ANALYST, I WANT TO...	...SO THAT...
U-101	Sign in with email + password (MFA only if my admin required it)	I'm not forced to set up MFA myself before my admin has decided to require it
U-102	See all connected sources at a glance with their last-pull status	I spot a broken connector immediately
U-103	Trigger an on-demand refresh on a source	I see the latest state without waiting for the next scheduled pull
U-104	Customize my dashboard by adding, resizing, repositioning, and configuring widgets	The dashboard reflects my workflow, not someone else's
U-105	Choose a starter "preset" for a new widget (e.g. "Pie • OS platform (top 5 + Other)")	Common configurations are one click away
U-106	Sort a bar chart by value or label and limit to top N with an "Other" bucket	I see the meaningful slices, not 47 long-tail values
U-107	Apply a color palette per chart (Default, Ocean, Sunset, Forest, Mono)	Charts in the same dashboard read consistently
U-108	Switch a line chart's range (7/14/30/90 days/all) and granularity (daily/weekly)	Long trends are readable without zooming
U-109	Color a stat / gauge based on user-set thresholds (good / warn / critical)	Compliance % at 65% looks different from compliance % at 95% at a glance
U-110	Click any pie slice, bar, stat, or gauge to see the underlying endpoints	I drill from "10 boxes are offline" to "which 10 boxes" in one click
U-111	Export the filtered drill-down to CSV	I can share the list with someone who has remediation access
U-112	Filter the full endpoint table by OS, health, compliance, agent version	I find the records I need for an investigation
U-113	Build a stat widget that counts endpoints matching a custom multi-condition rule (e.g. "Windows AND non-compliant AND last seen > 2 days ago")	I track metrics specific to my organization's policies

ID	AS AN ANALYST, I WANT TO...	...SO THAT...
U-114	Be alerted by email when a connector starts failing, and again when it recovers	I see ingest problems even if I'm not actively looking at the dashboard
U-115	Opt out of notification types I don't care about, in my Settings	My inbox isn't drowned by alerts that aren't relevant to me

6.3 P3 — Compliance Auditor / Executive stories

ID	AS A VIEWER, I WANT TO...	...SO THAT...
U-201	Sign in with a password (and MFA if my admin required it) and see only the dashboards an admin has shared with me	I can't accidentally see or change anything I shouldn't
U-202	See updates to the dashboard immediately when the admin owner changes the layout	I'm always looking at the current report, never a stale snapshot
U-203	Switch between multiple assigned dashboards from a dropdown	I can review different reports without bookmarks
U-204	Click any chart slice and see the underlying endpoint list	I can answer "which boxes are offline?" without asking the SOC
U-205	Read a clear explanation of what my role can and cannot do	I understand the boundaries of my access
U-206	Not see "Add source", "Customize dashboard", "Endpoint Data", or any other manager-only actions	The UI matches my permissions; nothing teases functionality I can't use
U-207	Be notified by email when a dashboard is newly assigned to me	I know I have a new report to review

7. Functional requirements

Each requirement is identified `F-AREA-###`, ties to user stories where relevant, declares acceptance criteria, and notes priority (**Must** / **Should** / **Could** for v1.0).

7.1 Authentication and session

F-AUTH-001 — EMAIL + PASSWORD SIGN-IN *(MUST)*

Description. Users sign in with email and password against the application's user store. Passwords are hashed with Argon2id (configurable memory / threads / time cost).

Linked stories. U-001, U-101, U-201.

Acceptance criteria.

- A user with `is_active = false` cannot sign in.
- A user whose `locked_until > now()` cannot sign in.
- Password mismatch returns a generic "invalid credentials" message

(does not leak whether the email exists).

- Successful sign-in establishes a Sanctum SPA cookie session.
- The session lifetime is 120 minutes (configurable via `SESSION_LIFETIME`).
- Sessions are encrypted at rest (`SESSION_ENCRYPT=true`).
- Every sign-in attempt (success or failure) writes a `login_events` row.

F-AUTH-002 — BRUTE-FORCE LOCKOUT *(MUST)*

Description. After N consecutive failed sign-ins for the same account, the account is locked for a configurable duration.

Linked stories. U-003.

Acceptance criteria.

- Default threshold: 8 failures (`security.max_login_attempts`).
- Default lockout: 15 minutes (`security.lockout_minutes`).
- On reaching the threshold, the account's `locked_until` is set and the `account.locked` notification fires to the default audience.
- A successful sign-in resets the failed counter.
- A `login.failed_threshold` notification fires when the soft threshold (max – 2) is reached, before the actual lockout, so admins can intervene.

F-AUTH-003 — IP BASELINING AND NEW-IP FLAGGING *(MUST)*

Description. The first IP for a user is established as the trusted baseline. Subsequent unrecognized IPs mark the session as flagged and trigger a notification.

Linked stories. U-002.

Acceptance criteria.

- The very first IP seen for a user is recorded as trusted; no flag is raised.
- Any subsequent new IP sets `users.ip_flagged = true` and fires the `login.new_ip` notification.
- The flag is surfaced in the topbar of the application and in the admin user list.
- An admin can clear the flag for a user, which also trusts that IP going forward.

F-AUTH-004 — SESSION CSRF PROTECTION *(MUST)*

Description. All mutating API requests require a valid CSRF token.

Acceptance criteria.

- `GET /sanctum/csrf-cookie` issues an `XSRF-TOKEN` cookie.
- Mutating requests (POST/PUT/DELETE) must include `X-XSRF-TOKEN` header matching the cookie.
- The frontend's `apiFetch` wrapper handles this automatically.

F-AUTH-005 — SESSION ACTIVITY TRACKING *(SHOULD)*

Description. The user's `last_seen_at` updates on every authenticated API call, supporting an "online now" indicator.

Acceptance criteria.

- Updates are throttled (not every request — once per minute is enough).
- The System Health page shows the count of users seen within the configured online window (default 5 minutes).

7.2 Multi-factor authentication

F-MFA-001 — TOTP ENROLLMENT *(MUST)*

Description. Users may enroll an RFC 6238 TOTP authenticator via QR code, with one-time recovery codes generated at enrollment.

Linked stories. U-001, U-007.

Acceptance criteria.

- The system uses `pragmarx/google2fa`.
- The setup screen displays a QR code (rendered client-side) and the manual entry secret.
- Confirmation requires a valid 6-digit code from the authenticator.
- Recovery codes are displayed once at enrollment and stored hashed.
- An audit log entry `mfa.enabled` is written.

F-MFA-002 — ADMIN-CONTROLLED ENROLLMENT FOR NON-ADMINS *(MUST)*

Description. Self-enrollment is restricted. Admins enroll MFA freely; analysts and viewers can only enroll when an admin has flagged their account with `mfa_required = true`.

Linked stories. U-006, U-101, U-201.

Acceptance criteria.

- `POST /api/mfa/setup` and `/api/mfa/confirm` return 403 unless the caller is an admin or has `mfa_required = true`.
- The Settings → MFA card hides enrollment controls for users who cannot self-enroll; it shows "MFA enrollment is controlled by your administrator."
- The admin Users dialog has a "Require MFA" button that flips the flag and writes `admin.mfa_required_set` to the audit log.
- The user the flag was set on sees enrollment controls on next sign-in.

F-MFA-003 — ADMIN-ONLY MFA DISABLE *(MUST)*

Description. Only admins can disable their own MFA. Non-admins must ask an admin (who calls `POST /api/admin/users/{user}/disable-mfa`).

Acceptance criteria.

- `POST /api/mfa/disable` returns 403 for non-admins.
- Admin disable wipes the secret + recovery codes and fires `account.mfa_disabled`.

F-MFA-004 — MFA CHALLENGE ON SIGN-IN *(MUST)*

Description. When MFA is enabled, sign-in is a two-step flow.

Acceptance criteria.

- After password validation, if MFA is enabled, the response indicates

`mfa_required: true` ; the session is not yet authorized.

- `POST /api/login/mfa` with a valid code completes sign-in.
- Recovery codes work once each and then are consumed.

7.3 Role-based access control

F-RBAC-001 — THREE ROLES *(MUST)*

Description. Every user has exactly one role: `admin` , `analyst` , or `viewer` . The `User` model exposes helpers `isAdmin()` and `canManage()` .

Acceptance criteria.

- Role is set on creation and editable by admins.
- An admin cannot remove their own admin role (prevents logout).
- Deleting the last admin is refused (422 with a clear message).

F-RBAC-002 — SERVER-SIDE ROUTE GATING *(MUST)*

Description. Authorization is enforced server-side, not relying on the frontend.

Acceptance criteria.

- `/api/admin/*` routes use the `EnsureRole:admin` middleware → 403

for non-admins.

- Manager-only mutations (`POST /api/dashboards` , `POST /api/sources` , `POST /api/sites` , ingest refresh) call `abort_unless($user->canManage(), 403)` .

• Per-resource ownership checks (dashboards, sources, sites) prevent cross-user access.

- Insights endpoints resolve sources from the requesting user's own

`apiSources()` , unless a `dashboard_id` is supplied for an assigned dashboard, in which case sources come from the dashboard owner.

F-RBAC-003 — CLIENT-SIDE GUARDS *(MUST)*

Description. Manager-only and admin-only pages render a permission notice and redirect when accessed by a viewer.

Linked stories. U-206.

Acceptance criteria.

- `<RoleGuard require="manage|admin">` wraps `/builder` , `/sources` , `/sources/new` , `/sources/[id]/edit` , `/data` .

- A viewer who navigates to one of these URLs sees a lock icon, the

message "You don't have permission to view this page", and is automatically redirected to `/` after a short delay.

- The sidebar hides items the user can't access (no teasing of unavailable functionality).

F-RBAC-004 — ROLES & PERMISSIONS EXPLAINER IN-APP *(MUST)*

Description. Every authenticated user can see what their role can do.

Linked stories. U-205.

Acceptance criteria.

- The Settings page includes a Roles & Permissions card.
- The Admin page includes a Roles & Permissions tab.
- The card shows a per-category permission matrix (Dashboards & Data, API Sources, Users & Admin, Account, System) with ✓ / X per role.
- The current user's role column is highlighted.
- The card also shows a three-card strip with each role's description, highlighting the current user's role.

7.4 User management (admin)

F-USER-001 — CREATE USER *(MUST)*

Description. Admin can create new users with name, email, role; an optional password (or auto-generated if omitted) is returned in the response so the admin can communicate it out-of-band.

Linked stories. U-004.

Acceptance criteria.

- Validation: email unique, role in {admin, analyst, viewer}, password $\geq$ 12 chars with mixed case / number / symbol if supplied.
- Auto-generated password is 16 characters, complex.
- New user is created with `must_change_password = true`.
- An audit log entry `admin.user_created` is written.

F-USER-002 — UPDATE USER ROLE / ACTIVE STATUS *(MUST)*

Description. Admin can change role and toggle active state.

Acceptance criteria.

- An admin cannot remove their own admin role (422).
- A role change fires the `account.role_changed` notification.

F-USER-003 — RESET PASSWORD *(MUST)*

Description. Admin can force a password reset for any user. Returns the new temporary password if auto-generated.

Linked stories. U-005.

Acceptance criteria.

- The user's `must_change_password` is set to true.
- Their failure counter and lockout are cleared.
- The `account.password_reset` notification fires, addressed to the affected user.

F-USER-004 — DELETE USER (WITH SAFEGUARD) *(MUST)*

Description. Admin can permanently delete a user account.

Linked stories. U-008.

Acceptance criteria.

- An admin cannot delete their own account (422 with clear message).
- An admin cannot delete the last remaining admin (422 with clear message).
- The UI requires the admin to type the target email exactly before the delete button enables.
- The delete cascades through FKs to the user's dashboards, sources, sites, login events, known IPs, and notification subscriptions.
- `audit_logs.user_id` is set to NULL on cascade (preserves the trail).
- An audit log entry `admin.user_deleted` is written.

F-USER-005 — CLEAR IP FLAG *(MUST)*

Description. Admin can clear the `ip_flagged` warning on a user and optionally promote their current IP into the trusted baseline.

Acceptance criteria.

- After clearing, `users.ip_flagged = false` and the current IP is recorded in `known_ips` as trusted.

F-USER-006 — UNLOCK ACCOUNT *(MUST)*

Description. Admin can unlock a user whose account has been locked by brute-force protection.

Acceptance criteria.

- `locked_until` is set to NULL and `failed_login_attempts` to 0.

7.5 API source connectors

F-SRC-001 — CONNECTOR FRAMEWORK *(MUST)*

Description. Vendor connectors live behind a shared interface. Adding a new vendor is a localized change.

Acceptance criteria.

- Vendors supported in v1.0: `generic` , `crowdstrike` , `defender` , `sentinelone` , `wazuh` , `trendmicro` , `cortex` , `cisco_amp` , `elastic` , `sophos` .
- `ConnectorFactory::make($source)` resolves the right class by `vendor` .
- Each connector accepts an `ApiSource` + decrypted secret and returns an iterable of raw records.

F-SRC-002 — AUTH TYPES *(MUST)*

Description. Connectors support four authentication modes.

Acceptance criteria.

- Supported: `bearer` , `api_key_header` , `basic` , `oauth2_client_credentials` .
- `oauth2_client_credentials` exchanges a `client_id` + secret for a token and includes the token in subsequent requests.

F-SRC-003 — VENDOR PRESETS IN WIZARD *(MUST)*

Description. The Add Source wizard offers per-vendor presets that pre-fill base URL, auth type, request config, and field mappings.

Linked stories. U-009.

Acceptance criteria.

- The wizard's step 1 is "vendor + preset". Selecting one populates the rest of the form.
- A "Generic" preset is always available.
- The presets endpoint also returns the list of refresh intervals.

F-SRC-004 — ENCRYPTED CREDENTIALS *(MUST)*

Description. Connector secrets (API keys, OAuth client secrets) are encrypted at rest with AES-256-GCM using a key independent from Laravel's `APP_KEY` .

Acceptance criteria.

- Encryption uses `App\Services\Crypto\SecretBox` keyed by `DATA_ENCRYPTION_KEY` .

- Format: `v1.` prefix + `base64(iv | tag | ciphertext)`.
- Decryption verifies the GCM auth tag; tampering causes failure.
- The plaintext secret is never logged or returned in any API response.

F-SRC-005 — TWO SECRET-STORAGE MODES *(MUST)*

Description. A source can either persist its secret (`saved`) or require an operator to re-enter it after each sign-in (`per_login`).

Acceptance criteria.

- `saved` mode encrypts and stores the secret. Scheduled refreshes work unattended.
- `per_login` mode keeps the secret in session memory only. Refreshes succeed only while at least one session has unlocked it.
- The wizard explains both modes clearly with their trade-offs.

F-SRC-006 — FIELD MAPPING *(MUST)*

Description. Each source has a JSON `field_mappings` object converting vendor-specific keys into the canonical endpoint shape.

Acceptance criteria.

- Default mappings ship per vendor preset.
- Admin can edit mappings via the wizard's step 3.
- Special prefix `_derived:*` triggers built-in normalizer logic (e.g. mapping `online_status` strings to `online / stale / offline`).

F-SRC-007 — REFRESH INTERVAL (15-MINUTE MINIMUM) *(MUST)*

Description. Each source has a configurable refresh interval. **Custom intervals are supported with a 15-minute minimum.**

Linked stories. Implicit from connector ops.

Acceptance criteria.

- Server-side validation: `min:15, max:10080` minutes (i.e. 15 min — 1 week).
- The wizard offers Preset chips (15/30/60/120/180/360/720/1440) AND a Custom numeric input with the same min/max.
- Custom values that are not in the preset list are auto-detected in edit mode and displayed in Custom mode pre-filled.
- A live "Current: every X minutes/hours" label updates as the user changes the value.

F-SRC-008 — ON-DEMAND REFRESH *(MUST)*

Description. Manager can trigger an immediate refresh of any source.

Linked stories. U-103.

Acceptance criteria.

- `POST /api/sources/{source}/refresh` invokes the ingest pipeline.
- The source's `last_run_at` and `last_status` update immediately.
- The Sources list shows a spinner and updates the row when complete.

F-SRC-009 — CONNECTOR FAILURE HANDLING *(MUST)*

Description. A failing source does not break the rest of the system.

Linked stories. U-114.

Acceptance criteria.

- Exceptions during fetch / normalize set `last_status = failed` and `last_error = <message>`, recorded on the source and the `source_run`.
- The dashboard shows the existing snapshot data (does not blank).
- A banner appears: "N source(s) failed to refresh: ...".
- The `source.refresh_failed` notification fires on the success → failed transition (not on every retry of a broken source).
- The `source.refresh_recovered` notification fires on the failed → success transition.

F-SRC-010 — TEST CONNECTION *(MUST)*

Description. Wizard step 2 can test the connection before saving.

Acceptance criteria.

- `POST /api/sources/test` validates credentials without writing the source.
- The response surfaces the HTTP status + first error line on failure.

7.6 Ingestion pipeline

F-ING-001 — SNAPSHOT MODEL *(MUST)*

Description. Each refresh persists a snapshot containing the endpoint count, a pre-aggregated summary JSON, and the normalized endpoint rows.

Acceptance criteria.

- `snapshots.summary` contains: `total, online, stale, offline,

compliant, non_compliant, compliance_pct, by_os{}, by_health{}, by_compliance{}, by_agent_version{}`.

- The snapshot is captured inside a single DB transaction; failures

leave the previous snapshot intact.

- The source's `latest_snapshot_id` points to the most recent successful snapshot.

F-ING-002 — ENDPOINT RETENTION *(SHOULD)*

Description. Detailed endpoint rows are pruned beyond a retention window to keep table sizes bounded; rolled-up summaries are kept for trends.

Acceptance criteria.

- A pruning step runs after each ingest.
- The retention window is configurable.

F-ING-003 — RUN LOG *(MUST)*

Description. Every ingest attempt writes a `source_runs` row.

Acceptance criteria.

- Columns: status, trigger (scheduled / on-demand / cli), timing, records_ingested, error_message.
- The UI can list recent runs per source.

7.7 Insights engine

F-INS-001 — SCOPE-AWARE QUERIES *(MUST)*

Description. Every insights endpoint accepts a `scope` parameter selecting which sources to aggregate.

Acceptance criteria.

- `scope=all` aggregates every source the user owns (or for an assigned dashboard, every source the dashboard owner has).
- `scope=site:{id}` narrows to a site's sources.
- `scope=source:{id}` narrows to a single source.
- If a saved scope no longer exists (source / site was deleted), the client gracefully falls back to "all".

F-INS-002 — DASHBOARD-AWARE SOURCE RESOLUTION *(MUST)*

Description. When a `dashboard_id` is supplied, sources are resolved from the dashboard owner (with access check), so viewers see real data on assigned dashboards.

Acceptance criteria.

- The user must own the dashboard or be in its `assignees` list, else 403.
- Owner's `apiSources()` are used; the `scope` filter is still applied

on top.

F-INS-003 — SUMMARY ENDPOINT *(MUST)*

Description. `GET /api/insights/summary` returns the merged summary across all sources in scope, plus error metadata.

Acceptance criteria.

- Sums numeric fields; merges the `by_*` distributions.
- Computes `compliance_pct = compliant / total * 100`.
- `last_error` is non-null when one or more sources are in `failed` state.

F-INS-004 — AGGREGATE ENDPOINT *(MUST)*

Description. `GET /api/insights/aggregate?field=...` returns `{field, buckets:[{label, value}]}` for any allowed field.

Acceptance criteria.

- Allowed fields: `hostname`, `os_platform`, `os_version`, `agent_version`,

`health_status`, `compliance_status`, `ip_address`, `mac_address`, `last_seen_at`, `external_id`, `is_isolated`.

- Sorted by count descending, limited to 30 buckets.
- NULL values bucketed as "Unknown".

F-INS-005 — TRENDS ENDPOINT *(MUST)*

Description. `GET /api/insights/trends` returns one row per day for the last 90 (configurable) days, summing across sources, using the latest snapshot per source-day to avoid double-counting.

Acceptance criteria.

- Returns: `captured_at`, `total`, `online`, `stale`, `offline`, `compliant`, `non_compliant`, `compliance_pct`.
- Configurable limit, capped at 365 days.

F-INS-006 — ENDPOINT DATA ENDPOINT *(MUST)*

Description. GET /api/insights/data returns paginated endpoints with filters and sort.

Linked stories. U-112.

Acceptance criteria.

- Filters: os_platform, os_version, health_status, compliance_status, agent_version, ip_address, mac_address, is_isolated, search, dashboard_id.
- Sort by any canonical field, asc/desc.
- Pagination: 25 default, max 200.

F-INS-007 — RULE EVALUATION *(MUST)*

Description. POST /api/insights/evaluate returns {count, total, pct} for a custom rule against in-scope endpoints.

Linked stories. U-113.

Acceptance criteria.

- Rule shape: {match: 'all'|'any', conditions: [{field, op, value}]}.
- Allowed fields: hostname, os_platform, os_version, agent_version, health_status, compliance_status, ip_address, mac_address, external_id, is_isolated, last_seen_days.
- Operators per field-type:
 - duration: gt, lt
 - enum: eq, neq, in
 - bool: eq
 - text: eq, neq, contains, not_contains, is_empty, not_empty
 - last_seen_days gt N matches endpoints last seen more than N days ago, OR never seen.

F-INS-008 — RULE DATA ENDPOINT *(MUST)*

Description. POST /api/insights/rule-data returns paginated endpoints matching a rule (powers drill-down on rule-based widgets).

Linked stories. U-110, U-111.

Acceptance criteria.

- Same rule shape and validation as evaluate.

- Returns the same endpoint shape as `/api/insights/data`.

7.8 Dashboard system

F-DASH-001 — PER-USER DASHBOARDS *(MUST)*

Description. Each manager owns one or more dashboards. One is flagged as default.

Acceptance criteria.

- The Dashboard page loads the user's default dashboard.
- The first time a manager visits with no dashboard, one is auto-created

from `DefaultDashboard::layout()`.

- A dashboard stores its layout as a JSON array of widget objects.

F-DASH-002 — DASHBOARD CRUD *(MUST)*

Description. Managers can create, update, rename, and delete their own dashboards.

Acceptance criteria.

- Endpoints: `POST /api/dashboards`, `PUT /api/dashboards/{id}`, `DELETE /api/dashboards/{id}`.
- Only the owner can mutate (server-side check returns 403 otherwise).
- Setting `is_default: true` un-sets it on all other dashboards of that

user.

- Audit log entries: `dashboard.created`, `dashboard.updated`, `dashboard.deleted`.

F-DASH-003 — DASHBOARD BUILDER *(MUST)*

Description. A drag-and-resize grid editor.

Linked stories. U-104.

Acceptance criteria.

- 12-column grid, 70-pixel row height.
- Drag handle is a dedicated grip icon (the rest of the card is click-pass-through).
- Add widget, edit, remove, and revert actions.
- Save commits the layout to the backend.

- Wrapped in `<RoleGuard require="manage">` server-checked too.

7.9 Widget catalog and customization

F-WIDG-001 — EIGHT WIDGET TYPES *(MUST)*

Description. v1.0 ships eight widget types.

Linked stories. U-104.

TYPE	PURPOSE
stat	Single metric or rule count
gauge	Percentage as a radial bar
pie	Distribution by a field
donut	Pie with hollow center
bar	Distribution by a field, optionally horizontal
line	Trend over time
area	Trend with filled area
table	Paginated endpoint table

F-WIDG-002 — PER-TYPE CONFIGURATION *(MUST)*

Description. Each widget type exposes a relevant set of knobs in the Edit dialog.

Linked stories. U-105 through U-109.

Acceptance criteria.

- **Stat/Gauge:** preset metric or rule; thresholds (good $\geq$, warn $\geq$, direction); unit suffix.
- **Pie/Donut/Bar:** group-by field; sort (value desc/asc, label asc, server order); top-N with "Other" bucket; palette; show legend; show values.
- **Bar:** + horizontal toggle.
- **Line/Area:** multi-series selection; time range (7/14/30/90/all days); granularity (day/week with client-side averaging); smooth toggle; y-axis suffix; palette; show legend.
- **Table:** no per-widget config.

F-WIDG-003 — PRESET WIDGET RECIPES *(MUST)*

Description. The Add Widget dialog includes a "Load preset" dropdown with 10 ready-to-use combinations.

Linked stories. U-105.

Acceptance criteria.

- Picking a preset fills the type, title, and every config field.
- The user can still tweak any field before saving.
- Recipes include: Total endpoints stat, Compliance % stat with

thresholds, Compliance % gauge, OS pie (top 5 + Other), Health donut, Agent versions horizontal bar (top 10), OS versions bar (top 5), Compliance trend line (30d daily), Health area (90d weekly), Endpoints table.

F-WIDG-004 — FIVE COLOR PALETTES *(SHOULD)*

Description. Each chart widget can apply one of five named palettes.

Linked stories. U-107.

Acceptance criteria.

- Palettes: Default, Ocean, Sunset, Forest, Mono.
- Health and compliance statuses use semantic colors regardless of palette (online=green, offline=red, etc.).

F-WIDG-005 — THRESHOLD COLORING *(SHOULD)*

Description. Stat and gauge widgets can change color based on user-defined thresholds.

Linked stories. U-109.

Acceptance criteria.

- Two thresholds (good $\geq$, warn $\geq$) plus direction (higher_is_better / lower_is_better).
- Colors: success (green) $\geq$ good; warning (amber) $\geq$ warn; destructive (red) below.
- Threshold-only widgets without a metric mapping fall back to the primary color.

7.10 Widget drill-down

F-DRILL-001 — CLICK-TO-DRILL ON CHARTS *(MUST)*

Description. Clicking any data point on a chart opens a modal listing the underlying endpoints.

Linked stories. U-110, U-204.

Acceptance criteria.

- Pie / donut slice → filter by `{field, value}` .
- Bar (vertical or horizontal) → filter by `{field, value}` .
- "Other" rollup bucket is NOT clickable (it's an aggregate).
- Cursor turns into a pointer on clickable elements with a "Click to

see matching endpoints" tooltip.

- Disabled inside the Customize Dashboard builder (chart clicks don't pop dialogs while editing).

F-DRILL-002 — CLICK-TO-DRILL ON STAT / GAUGE *(SHOULD)*

Description. Stat and gauge widgets are clickable when the metric maps cleanly to a filter or to a rule.

Acceptance criteria.

- `metric=online|stale|offline` → filter `health_status` .
- `metric=compliant|non_compliant` → filter `compliance_status` .
- `metric=total` → no filter (all endpoints in scope).
- `metric=compliance_pct` → not clickable.
- Rule-based stat/gauge → rule-data drill.

F-DRILL-003 — DRILL DIALOG UX *(MUST)*

Description. The drill modal mirrors the full endpoint table but filtered.

Linked stories. U-110, U-111.

Acceptance criteria.

- Columns: hostname, OS, OS version, agent, health, compliance, last seen, IP.
- Sortable columns.
- 25 per page with prev/next pagination.
- A search input narrows further (disabled in rule mode).
- An "Export CSV" button downloads the current filter as `endpoints-<value>.csv` .
- Works for viewers via `dashboard_id` parameter.

7.11 Dashboard sharing (assignment)

F-SHARE-001 — ADMIN ASSIGNS DASHBOARDS TO VIEWERS *(MUST)*

Description. Admins can grant viewers read-only access to one or more of their own dashboards.

Linked stories. U-011.

Acceptance criteria.

- The Admin → Manage user dialog has an "Assigned dashboards" section.
- Admin can pick from any dashboard owned by a manager (admin or analyst).
- Admin cannot assign a dashboard a user already owns.
- Pivot row records `dashboard_id`, `user_id`, `assigned_by_user_id`.
- `dashboard.assigned` notification fires to the assignee.

F-SHARE-002 — LIVE UPDATES, NOT SNAPSHOTS *(MUST)*

Description. Assignments are live links to the admin's dashboard. Admin layout edits propagate immediately to viewers.

Linked stories. U-202.

Acceptance criteria.

- The viewer's UI fetches the dashboard from the same `dashboards` row the owner edits; no copy is made.
- The viewer cannot modify the layout (write returns 403).
- On a new page load, the viewer sees the latest layout.

F-SHARE-003 — VIEWER DASHBOARD SWITCHER *(MUST)*

Description. If a viewer has more than one assigned dashboard, the Dashboard page shows a dropdown to switch between them.

Linked stories. U-203.

Acceptance criteria.

- The switcher lists each assignment with the owner's name.
- The first-assigned dashboard is the default.
- A view-only banner appears at the top: "View-only dashboard assigned by {owner}. Updates from the owner appear automatically."

F-SHARE-004 — AUDIT LOG OF VIEWER ACCESS *(MUST)*

Description. Every viewer load of an assigned dashboard writes an audit log entry.

Linked stories. U-012.

Acceptance criteria.

- `dashboard.viewed` rows in `audit_logs` record `user_id`, `dashboard_id`, `dashboard_name`, owner ID, and the way it was loaded (default vs switcher).
- Admin can filter the Audit Log tab by this action.

F-SHARE-005 — EMPTY STATE FOR VIEWERS WITHOUT SOURCES *(MUST)*

Description. Viewers with no own sources and no assigned dashboards see a friendly empty state, not an error.

Acceptance criteria.

- The dashboard page renders an "Eye" icon, the line "No dashboard assigned", and the hint "Ask an administrator to assign a dashboard to your account."

7.12 Endpoint data view

F-DATA-001 — ENDPOINT DATA PAGE *(MUST)*

Description. A standalone page with the full endpoint table.

Linked stories. U-112.

Acceptance criteria.

- Manager-only (wrapped in `<RoleGuard require="manage">`).
- Search, OS / health / compliance filters at the top.
- Export CSV.
- Scope selector at the top.

7.13 Email notification system

F-NOTIF-001 — TEN EVENT TYPES *(MUST)*

Description. v1.0 ships ten notification events across five categories.

Linked stories. U-014, U-114, U-115, U-207.

EVENT KEY	CATEGORY	DEFAULT AUDIENCE
login.new_ip	security	admins
login.failed_threshold	security	admins
account.locked	security	admins
account.mfa_disabled	account	admins
account.password_reset	account	the affected user
account.role_changed	account	admins
dashboard.assigned	dashboard	the affected user
source.refresh_failed	source	admins + analysts
source.refresh_recovered	source	admins + analysts
vuln.new_advisory	vulnerability	admins

Acceptance criteria.

- Each event is defined in `NotificationCatalog::events()` with display name, category, default severity, available variables, and default audience.
- Templates are seeded from the catalog and editable via the admin UI.
- A template can be disabled to suppress that notification globally without losing its content.

F-NOTIF-002 — EDITABLE TEMPLATES WITH LIVE PREVIEW *(MUST)*

Description. Admin can edit subject + HTML body + plain-text fallback in a dialog with a live preview pane.

Linked stories. U-014.

Acceptance criteria.

- The editor has tabs for HTML and Plain-text bodies.
- A sidebar lists available `{{ variable }}` names for the event; clicking inserts at the current cursor of the active tab.
- A live preview renders the template with realistic sample payload.
- A "Send test to me" button delivers a copy with `[TEST]` subject prefix.
- A "Reset to default" button restores the catalog default.
- A per-template enable/disable checkbox.

F-NOTIF-003 — MUSTACHE-LITE TEMPLATE ENGINE *(MUST)*

Description. Templates use `{{ key }}` and `{{ nested.key }}` syntax. No control flow, no PHP — safe to expose to admin editing.

Acceptance criteria.

- Missing keys render as the literal placeholder, so admins notice typos.
- Each event has a documented set of variables plus shared variables `app.name`, `event_key`, `recipient.name`, `recipient.email`.

F-NOTIF-004 — RUNTIME SMTP CONFIGURATION *(MUST)*

Description. SMTP credentials are configured in the admin UI, not in `.env`. The password is encrypted at rest with `SecretBox`.

Linked stories. U-013.

Acceptance criteria.

- The Mail Settings tab allows configuring transport (smtp/log), host,

port, encryption (tls/ssl/none), username, password, from address, from name, reply-to.

- A master `enabled` switch can pause all outbound mail without losing settings.
- "Send test email" button validates the configuration and surfaces any SMTP error inline.
- Saving the form clears Laravel's mailer cache so the next send uses the new config.

F-NOTIF-005 — PER-USER SUBSCRIPTIONS WITH ROLE DEFAULTS *(MUST)*

Description. Each user can opt in or out of any event type. Missing preferences inherit the role default.

Linked stories. U-115.

Acceptance criteria.

- Settings → Email notifications lists every event with a toggle.
- The default state for each event is shown in subtle text ("default: on").
- Toggling creates an explicit subscription row that overrides the default.
- Admins can edit any user's subscriptions from the admin user dialog (future — currently the user must opt in themselves).

F-NOTIF-006 — REAL-TIME TRIGGERS WIRED INTO EXISTING FLOWS *(MUST)*

Description. Events fire from the actual flows that produce them, not from an out-of-band scanner.

Linked stories. U-002, U-006, U-016, U-114, U-207.

Acceptance criteria.

- `LoginSecurityService` dispatches `login.new_ip`, `login.failed_threshold`, `account.locked`.
- `AdminController` dispatches `account.mfa_disabled`, `account.password_reset`, `account.role_changed`, `dashboard.assigned`.
- `IngestService` dispatches `source.refresh_failed` (only on the success → failed transition) and `source.refresh_recovered`.
- `TechStackAuditor` dispatches `vuln.new_advisory` for advisories not seen in the previous scan; the first-ever scan only baselines.

F-NOTIF-007 — NOTIFICATION LOG *(MUST)*

Description. Every send attempt is logged.

Acceptance criteria.

- `notification_logs` rows record `user_id`, `event_key`, `channel`

(always "email" in v1.0), `recipient`, `subject`, `status` (queued / sent / failed / skipped), `error`, `payload snapshot`, `sent_at`.

- The Admin → Notification Log tab shows the last 200 sends.

7.14 Tech stack and vulnerability scanner

F-VULN-001 — TECH STACK INVENTORY *(MUST)*

Description. A panel on the System Health page lists every PHP and npm package installed.

Linked stories. U-015.

Acceptance criteria.

- Admin-only.
- Reads PHP packages from `composer.lock`, npm packages from

`Frontend/package-lock.json`.

- Shows ecosystem, name, version, dev flag, advisories count, status badge.
- Searchable by name or version.
- Filterable by ecosystem (PHP / npm), severity (vulnerable-only, critical, high, moderate, low), and include-dev toggle.
- Vulnerable rows are red-tinted and sorted to the top.

F-VULN-002 — LIVE CVE / GHSA ENRICHMENT *(MUST)*

Description. Advisories come from live queries against Packagist and the GitHub Advisory Database.

Linked stories. U-015.

Acceptance criteria.

- `composer audit --format=json --no-interaction --locked` for PHP.
- `npm audit --json --omit=dev` for npm, run from the Frontend folder.
- Each advisory shows: CVE or GHSA identifier, severity, CVSS score

(when available), affected version range, title, advisory URL.

- Where npm omits a CVE, the GHSA ID is extracted from the advisory URL and used as the identifier.
- Results are cached for 1 hour. A Refresh button forces a re-scan.

F-VULN-003 — RUNTIME VERSION STRIP *(MUST)*

Description. The panel shows runtime versions across the top.

Acceptance criteria.

- Tiles for PHP, Laravel, Node.js, npm, Composer, Database.
- Versions detected via `php -v` style commands; missing tools render

as "—" without breaking the panel.

F-VULN-004 — NEW-ADVISORY NOTIFICATIONS *(MUST)*

Description. When a scan finds advisories not seen previously, a notification fires.

Linked stories. U-016.

Acceptance criteria.

- Comparison key: `(ecosystem | name | version | identifier)`.
- The first-ever scan only baselines and emits nothing.
- Each new advisory dispatches `vuln.new_advisory` with the full

metadata in the payload.

F-VULN-005 — OPERATIONAL RESILIENCE *(SHOULD)*

Description. When one audit fails the other still surfaces results.

Acceptance criteria.

- 60-second timeout per audit.
- Failure mode renders a yellow warning strip with the source and a truncated error.
- The other ecosystem's results still render.

7.15 Audit trail**F-AUDIT-001 — COMPREHENSIVE AUDIT LOG *(MUST)***

Description. Every administrative and security-relevant action is recorded.

Linked stories. U-012, U-017.

Acceptance criteria.

- Actions covered include:
- Auth: `auth.login`, `auth.login_failed`, `auth.logout`.
- MFA: `mfa.enabled`, `mfa.disabled`, `mfa.recovery_codes_regenerated`, `admin.mfa_disabled`, `admin.mfa_required_set`.
- Account admin: `admin.user_created`, `admin.user_updated`,

`admin.user_deleted` , `admin.password_reset` , `admin.user_unlocked` ,
`admin.ip_flag_cleared` .

- Dashboards: `dashboard.created` , `dashboard.updated` ,
`dashboard.deleted` , `dashboard.assigned` , `dashboard.unassigned` , `dashboard.viewed` .
- Notifications: `notification.template_updated` ,
`notification.subscriptions_updated_for_user` , `mail.settings_updated` .
- The Admin → Audit Log tab shows the last 200 entries with actor,
target type+id, IP, timestamp, and a meta JSON badge.
- Deleting a user nulls `user_id` on their audit log entries
(preserves the trail).

7.16 System Health

F-HEALTH-001 — SUBSYSTEM PANELS *(MUST)*

Description. The Health page shows the status of every key subsystem.

Linked stories. U-017.

Acceptance criteria.

- Panels: Application, Database, Cache, Queue, Scheduler, Sources,
Security Posture.
- Each panel has a status badge (Healthy / Degraded / Error).
- The page auto-refreshes every 30 seconds.
- Scheduler is marked Degraded if its last-run timestamp is older than
10 minutes.

F-HEALTH-002 — TECH STACK PANEL *(MUST)*

Description. The vulnerability panel is rendered on the Health page for admins. See section 7.14.

7.17 Settings (per user)

F-SET-001 — ACCOUNT INFO CARD *(MUST)*

Description. Shows the user's name, email, role.

F-SET-002 — CHANGE PASSWORD CARD *(MUST)*

Description. Lets the user change their own password, requiring the current password.

Acceptance criteria.

- Password complexity $\geq$ 12 characters with mixed case + number + symbol.

F-SET-003 — MFA CARD *(MUST)*

Description. Renders different controls based on the user's permission to self-enroll.

Acceptance criteria.

- Admins see full enrollment / regenerate codes / disable controls.
- Users with `mfa_required = true` see the enrollment flow.
- Other users see status-only with an explanatory line.

F-SET-004 — NOTIFICATION PREFERENCES CARD *(MUST)*

Description. Per-event toggles. See section 7.13.

F-SET-005 — ROLES & PERMISSIONS CARD *(MUST)*

Description. The same explainer card that admins see. See F-RBAC-004.

8. Non-functional requirements

8.1 Security

ID	REQUIREMENT
NFR-SEC-001	Passwords hashed with Argon2id (configurable memory / threads / time cost)
NFR-SEC-002	Connector secrets and SMTP passwords encrypted with AES-256-GCM using a key independent from APP_KEY
NFR-SEC-003	All mutating API requests require a valid CSRF token
NFR-SEC-004	Brute-force lockout active by default
NFR-SEC-005	New-IP flagging on by default
NFR-SEC-006	RBAC enforced server-side; client guards are convenience, not security
NFR-SEC-007	Sensitive fields (password , MFA secrets, recovery codes) hidden from JSON serialization
NFR-SEC-008	Session cookies are HttpOnly ; sessions encrypted at rest
NFR-SEC-009	Every security-relevant action is audit-logged
NFR-SEC-010	The system audits its own dependencies for CVEs

8.2 Performance

ID	REQUIREMENT
NFR-PERF-001	Dashboard initial load < 2s on a typical estate (1–5 sources, 5k endpoints)
NFR-PERF-002	API endpoints respond < 500ms p95 (excluding ingest and audits)
NFR-PERF-003	Tech stack scan completes within 30s (cached 1h)
NFR-PERF-004	Ingest of a 10k-endpoint source completes within 60s on stock hardware
NFR-PERF-005	Endpoint table pagination at 25/page returns within 250ms p95

8.3 Reliability

ID	REQUIREMENT
NFR-REL-001	A failing source does not blank the dashboard — last successful snapshot is displayed
NFR-REL-002	A failed notification send does not break the triggering flow
NFR-REL-003	Ingest writes are wrapped in a DB transaction; partial failures don't corrupt data
NFR-REL-004	Tech stack scan handles missing tools gracefully (returns blank for that ecosystem)
NFR-REL-005	Source secret decryption failures don't poison the entire run; the source is marked failed

8.4 Compatibility

ID	REQUIREMENT
NFR-COMPAT-001	Server: PHP 8.3+
NFR-COMPAT-002	Server: Node 20+
NFR-COMPAT-003	Server: MySQL 8 or MariaDB 10.4+
NFR-COMPAT-004	Browser: latest 2 versions of Chrome, Edge, Firefox, Safari
NFR-COMPAT-005	Self-hostable on a single Linux VPS with Nginx + PHP-FPM + MySQL

8.5 Maintainability

ID	REQUIREMENT
NFR-MAINT-001	Backend and frontend are in separate repos for independent deploy
NFR-MAINT-002	All API responses are TypeScript-typed end-to-end
NFR-MAINT-003	Adding a new notification event is a one-file change in the catalog
NFR-MAINT-004	Adding a new connector vendor is a localized change
NFR-MAINT-005	Default templates and seeded users are idempotent (<code>updateOrCreate</code>)

8.6 Usability

ID	REQUIREMENT
NFR-USE-001	Every chart that filters down to endpoints is clickable for drill-down
NFR-USE-002	Destructive actions (delete user, delete source) require confirmation
NFR-USE-003	UI never shows controls a user cannot use (better to hide than to disable)

ID	REQUIREMENT
NFR-USE-004	All errors surface as toast notifications with a useful message
NFR-USE-005	The Roles & Permissions matrix is visible to every user, not just admins

8.7 Observability

ID	REQUIREMENT
NFR-OBS-001	System Health page surfaces subsystem status
NFR-OBS-002	All admin actions audit-logged
NFR-OBS-003	Notification send log is browseable
NFR-OBS-004	Source run log is browseable per source

9. Acceptance criteria summary

A v1.0 release is considered complete when:

1. All **Must** functional requirements (sections 7.1–7.17) pass their acceptance criteria.
 1. The persona coverage matrix (section 5.4) is satisfied — every feature serves at least one persona.
 1. All non-functional requirements (section 8) are demonstrably met on a reference deployment.
 1. The seeded default users (`admin@compliance.local` , `analyst@compliance.local` , `viewer@compliance.local`) can each sign in and exercise the persona stories in section 6.
 1. Documentation (this PRD and the Technical Reference) is up to date and PDF-exportable.
-

10. Success metrics

How we'll know v1.0 is delivering value.

10.1 Activation

METRIC	TARGET	WHY
Time to first connected source	< 15 min from fresh deploy to first successful ingest	Onboarding friction kills products
Time to first dashboard customization	< 30 min from sign-in to a saved custom widget	Builder must be discoverable, not buried

10.2 Engagement

METRIC	TARGET	WHY
Weekly active rate (P1+P2)	≥ 80% within first month	If managers aren't logging in weekly, the product isn't load-bearing
Weekly active rate (P3 viewers)	≥ 50%	Viewers are intermittent users; lower bar is realistic
Median custom widgets per manager	≥ 3	A dashboard that's never customized is just a default dashboard

10.3 Coverage

METRIC	TARGET	WHY
% of estate represented in the dashboard	≥ 95% of known endpoints	Anything missing creates a blind spot
Mean source refresh interval	≤ 60 min	Stale data erodes trust

10.4 Operational

METRIC	TARGET	WHY
Mean time to detect a failed source	≤ 1 ingest cycle (from notification)	Was previously discovered by accident
Mean time to detect a new CVE in our own stack	≤ 24 h	Was previously never
Audit log completeness	100% of administrative actions recorded	Compliance hard requirement

10.5 Security

METRIC	TARGET	WHY
% of admin accounts with MFA enabled	100%	Privilege requires phishing-resistant auth
Failed-login lockouts triggered by brute force	All resolved within 4 h	Lockouts are an alert, not an end state
Audit log retention	≥ 365 days	Compliance hard requirement

11. Out of scope for v1.0

The following are intentionally excluded from the initial release. They may be reconsidered for future versions.

AREA	WHY OUT OF SCOPE FOR V1.0
Mobile native apps	Responsive web is sufficient for the workflows targeted
Real-time push (WebSockets)	EDR APIs are polled; sub-minute updates would not change the data anyway
Multi-tenant SaaS	The product is designed for single-tenant self-hosted use
AI / ML anomaly detection	Threshold + rule-based detection is sufficient for v1.0
Ticketing / SOAR integration	Remediation belongs in dedicated tools
Endpoint remediation actions (isolate, kill process)	Read-only by design
Granular per-dashboard / per-widget RBAC	Three-role model satisfies v1.0 use cases
Shared dashboard collaboration (real-time co-editing)	Out of scope; dashboards are single-owner
Per-dashboard scheduled email exports / digests	Out of scope; notifications are real-time only in v1.0
OIDC / SAML SSO	Local auth is sufficient for first deployments; can be added later
Webhook / Slack / Teams destinations for notifications	Email is the v1.0 channel; other channels are roadmap
Custom report builder (PDF / Excel exports of dashboards)	CSV exports of drill-downs cover the v1.0 need
Endpoint detail page (single-endpoint history view)	Drill-down to a list is sufficient for v1.0
Daily digest emails	Real-time triggers were chosen for v1.0
Threshold-based notifications (e.g. "compliance < 80%")	Real-time event triggers were chosen for v1.0

12. Roadmap (post-v1.0 candidates)

Ranked roughly by user value and implementation effort. Not commitments — these are signals about where the product can go next.

12.1 Next quarter

ITEM	WHY
Daily digest emails	Reduce inbox load for events that don't need instant attention
Threshold-based notifications (e.g. compliance < 80%)	Catches drift without spamming on every minor change
Scheduled CVE scans (daily)	Catches new disclosures even when no admin visits Health page
Queue worker by default (notifications async)	Removes SMTP slowness from user-facing flows
Slack / Teams notification destinations	Many SOCs live in chat, not email

12.2 Following quarter

ITEM	WHY
Endpoint detail page with history timeline	The natural next click after drill-down
OIDC / SAML SSO	Required for enterprise adoption
Webhook destinations (generic)	For PagerDuty, Opsgenie, custom integrations
Per-dashboard scheduled PDF email exports	The most-requested "give me my Monday morning report" feature
Bulk admin actions (multi-user role change, multi-source refresh)	Quality-of-life for larger estates

12.3 Longer term

ITEM	WHY
Multi-tenant SaaS option	If we choose to offer a hosted version
ML anomaly detection on trends	"This is unusual for a Tuesday morning"
Custom report builder	Beyond what notifications + drill-downs can produce
Mobile app	For on-call notifications
Endpoint remediation actions through connector APIs (with safety controls)	Closes the loop from detection to fix

13. Risks and open questions

13.1 Risks

ID	RISK	SEVERITY	MITIGATION
R-001	Loss of <code>DATA_ENCRYPTION_KEY</code> makes every saved secret undecryptable	Critical	Documented in deployment guide; recommend secure off-box backup of <code>.env</code>
R-002	Single-instance scaling limit	Medium	Most heavy work (ingest, notifications, audits) is already queue-able; switching to Redis queue is a 1-line change
R-003	Vendor API drift breaks a connector	Medium	Source failures isolate; admin gets notified; can edit field mappings without redeploy
R-004	SMTP credentials exposed via <code>notification_logs.payload</code>	Low	Payload only contains the rendered message body, not the SMTP credentials
R-005	Notification triggers run synchronously inside user flows	Medium	Documented; queueing is the recommended production hardening
R-006	Tech stack audit shells out to <code>composer / npm</code> ; depends on <code>PATH</code> being correct under PHP-FPM	Low	Documented in operational notes; degrades gracefully when missing
R-007	Single-tenant data model — admins can see all users	High if used multi-tenant	Documented as a non-goal; not for shared deployments
R-008	Viewers see endpoint data from the dashboard owner's sources via <code>dashboard_id</code> — must be access-checked correctly	High	Dedicated check in <code>InsightsController::dashboardOwner()</code> ; refusing 403 if not in assignees
R-009	Brute-force lockout could be used as a denial-of-service against a specific user	Medium	Lockout is short (15 min default); admin can unlock; consider IP-based throttling as v1.1

13.2 Open questions

ID	QUESTION	OWNER
Q-001	How do we want to handle <code>DATA_ENCRYPTION_KEY</code> rotation? Currently no rotation; ciphertexts include a <code>v1.</code> prefix to support a future re-encryption job.	Engineering

ID	QUESTION	OWNER
Q-002	Should default dashboard be admin-configurable (vs hard-coded in <code>DefaultDashboard::layout()</code>)?	Product
Q-003	Should notification template "Reset to default" preserve admin edits as a draft to allow comparison?	Product
Q-004	Should we support multiple SMTP profiles (e.g. test vs production), or stay with one?	Product
Q-005	Do we expose source ingest scheduling at sub-15-minute resolution for opt-in customers, or keep 15-minute floor as a global rule?	Product
Q-006	Should viewers be allowed to drill-down (which exposes endpoint detail), or should drill-down also be gated by role?	Product / Security
Q-007	Audit log retention is currently unbounded — do we want a configurable retention window?	Compliance

14. Glossary

TERM	DEFINITION
EDR	Endpoint Detection & Response — security tools that monitor endpoint behavior
XDR	Extended Detection & Response — broader endpoint + network + cloud detection
SIEM	Security Information & Event Management — log aggregation + correlation
Endpoint	A managed device (workstation, server, mobile) with an EDR agent installed
Snapshot	A point-in-time crystallization of a source's endpoint inventory
Source	A configured connection to a vendor's API, owned by one user
Connector	The code class that knows how to talk to a specific vendor's API
Site	A grouping of sources, typically by geographic location or org unit
Scope	A query parameter selecting which sources to aggregate (<code>all</code> , <code>site:N</code> , <code>source:N</code>)
Widget	A single chart, stat, gauge, or table on a dashboard
Dashboard	A user's named arrangement of widgets, persisted as a JSON layout
Drill-down	Clicking a chart slice to see the underlying endpoints
MFA / 2FA	Multi-factor / Two-factor authentication — a second proof of identity beyond a password
TOTP	Time-based One-Time Password (RFC 6238); the standard for authenticator apps
GHSA	GitHub Security Advisory — the unique identifier for advisories in GitHub's database
CVE	Common Vulnerabilities and Exposures — the industry-standard advisory identifier
CVSS	Common Vulnerability Scoring System — a numeric severity score 0.0–10.0
Sanctum SPA	Laravel's session-cookie authentication mode for single-page applications
Argon2id	Memory-hard password hashing function; the modern standard
AES-256-GCM	Authenticated symmetric encryption (256-bit key, GCM mode)
Admin / Analyst / Viewer	The three roles in v1.0; see section 7.3
Default audience	Per notification event, the roles whose users receive it by default
Live link assignment	Dashboard sharing model where the viewer sees the owner's current dashboard, not a copy

Appendix A — Default seeded users

For development and demo purposes the seeder creates three users:

```
admin@compliance.local    / Admin@12345!    → admin
analyst@compliance.local  / Analyst@12345!   → analyst
viewer@compliance.local   / Viewer@12345!    → viewer
```

These credentials must be rotated before any production exposure.

Appendix B — Reference deployment

The reference deployment runs on a single Linux VPS:

- Nginx as reverse proxy + TLS terminator (Let's Encrypt)
- PHP-FPM 8.3
- MySQL 8
- Node.js 20+ running the Next.js frontend under PM2
- Two domains: `api.<your-domain>` and `app.<your-domain>`
- Two site users (one per app), each owning their respective folder

hierarchy

See the Technical Reference, section "Deployment", for the full sequence.

End of Product Requirements Document.